

项目审计问题摘要

基于当前 main 分支的只读静态审计

审计结论			
当前项目适合课程设计和功能演示，但尚不具备公网生产上线所需的判题可靠性、沙箱隔离和运维保障。			

3	7	372	122
阻断级问题	高风险问题	受控文件	测试声明

审计基线

- 分支：main；HEAD：97004bde09d977b2f3df5fb3621949833f2e6559。
- 技术栈：ASP.NET Core / EF Core / PostgreSQL / Redis / React / Docker JudgeWorker。
- 未修改任何项目源码；报告文件为本次唯一交付物。
- 为遵守只读要求，未运行会生成 bin、obj、dist、node_modules 或 TestResults 的构建与测试。

1. 风险总览

等级	数量	核心主题	结论
P0 阻断	3	队列可靠性、Hidden 测试隔离、Worker 资源耗尽	公开上线前必须修复
P1 高风险	7	发布状态、空测试点、身份安全、输入边界、部署	应进入首轮整改
P2 中风险	若干	判题指标、文件一致性、CSV、测试与文档	纳入上线前收口

总体判断：业务功能覆盖较完整，分层方向基本正确；但判题链路仍采用至多一次消费，沙箱未实现测试点级隔离，生产部署也缺少持久化、健康检查、TLS、备份和恢复闭环。

2. P0 阻断级问题

P0	判题任务可能永久丢失或卡死
问题	Submission 在数据库事务提交前写入 Redis；Worker 使用破坏性 LPOP，并在异常后仅记录日志。
影响	Worker 可在数据库提交前消费任务；进程退出、Docker 或数据库异常后，提交可能永久停留在 Pending 或 Judging。Redis 重启也会丢失未持久化队列。
建议	引入数据库 Outbox 或 processing-list + ACK/租约；消费需幂等；启动时恢复超时 Pending/Judging；失败必须落入明确终态。
证据	OnlineJudge.Infrastructure/Submissions/SubmissionService.cs:73-104；OnlineJudge.JudgeWorker/Worker.cs:27-35、87-89、144-150

P0	Hidden 测试输入可被参赛代码读取
问题	全部测试输入在编译前写入同一工作目录，随后以可读写方式挂载给每一个运行容器。
影响	恶意程序可枚举全部 .input.txt，在 Sample 测试中输出 Hidden 输入，还可修改未来测试输入或运行文件，破坏保密性与判题完整性。
建议	每个测试点使用独立目录；只注入当前输入；程序文件只读；测试输入不要作为可枚举共享文件暴露。
证据	OnlineJudge.Infrastructure/Judging/Sandbox/DockerJudgeSandbox.cs:39-41、96-105、199-216

P0	无限输出可耗尽 JudgeWorker 内存
问题	stdout 和 stderr 被无上限追加到宿主 StringBuilder，容器内存限制不覆盖 Worker。
影响	用户程序可高速输出导致宿主 OOM。超时时只杀 docker CLI，容器是否残留尚未通过真实 Docker 验证。
建议	设置严格输出字节上限并超限终止；保存容器 ID并显式 stop/kill；增加孤儿容器清理和运行级测试。
证据	OnlineJudge.Infrastructure/Judging/Sandbox/DockerJudgeSandbox.cs:218-235、244-254、346-353

3. P1 高风险问题

P1	未发布题目和挑战缺少服务端访问控制
问题	匿名列表和详情返回未发布 Problem、Challenge 与 Task；提交路径也未检查 IsPublished。
影响	草稿内容可被匿名查看；未发布算法题和文件任务可绕过前端直接提交或计分。
建议	拆分公开查询与管理查询；所有答题入口统一校验 Challenge、Task 和 Problem 的发布状态及开放时间。
证据	ProblemService.cs:20-55；ChallengeService.cs:27-72；SubmissionService.cs:35-37、364-392；ChallengeService.cs:991-1022

P1	零测试点题目会直接 Accepted
问题	沙箱默认 overallStatus 为 Accepted；TestCases 为空时循环跳过并直接返回。
影响	空题目可产生错误 Accepted；挑战算法任务可能因此获得满分。
建议	禁止无测试点题目发布和提交；Worker 再做防御性检查，并返回 SystemError 或配置错误。
证据	DockerJudgeSandbox.cs:89-96、174-180；ProblemService.cs:643-743

P1	注册密码策略过弱且认证接口缺少全局限流
问题	注册仅要求密码非空；API 未配置 RateLimiter、登录锁定或 IP 级发送限制。
影响	允许单字符密码；登录、注册验证码和密码重置接口易受暴力破解与批量发送滥用。
建议	建立统一密码策略；对登录、发送和确认接口增加用户/IP/设备多维限流及失败审计。
证据	AuthService.cs:24-31；OnlineJudge.Api/Program.cs:12-64

P1	验证码校验不是原子操作
问题	Redis 校验采用 GET、内存计数、SET/DELETE 的多步读改写流程。
影响	并发请求可覆盖 AttemptCount；正确验证码可能被并发消费多次。
建议	使用 Redis Lua 脚本或事务，将比较、次数递增、TTL 保留和成功删除变成原子操作。
证据	EmailVerificationService.cs:78-125；SmsVerificationService.cs:64-110

P1	注销或拉黑状态没有在所有入口统一生效
问题	多个服务只检查 IsBlacklisted，不检查 IsDeleted；图片上传仅依赖 JWT 的 [Authorize]。
影响	已注销用户在 Token 过期前仍可提交或参加挑战；被拉黑和注销用户仍可能上传图片并占用磁盘。
建议	统一 ActiveUser 授权要求；所有受保护端点在数据库中重新确认用户有效状态。
证据	SubmissionService.cs:287-308；ChallengeService.cs:1182-1203；ProfileService.cs:41-62；UploadsController.cs:7-34

P1	输入、资源和批量操作缺少统一上限
问题	请求模型没有统一验证；题目标题、时间/内存限制、源码长度和测试点导入规模缺少完整边界。
影响	异常值可能进入数据库或变成 500；巨大源码、描述和批量导入可形成内存、存储与判题资源滥用。
建议	在 API 和领域服务双层设置长度、数量、时间、内存与总字节限制；增加统一 ProblemDetails 异常处理。
证据	OnlineJudge.Application/*/Requests；ProblemService.cs:643-743；SubmissionService.cs:25-32

P1	生产部署基线尚未建立
问题	Compose 只定义 PostgreSQL 与 Redis，且发布宿主端口；缺少 Redis 持久化、健康检查、服务编排、TLS、备份与日志轮转。
影响	数据库、队列、上传文件和 JudgeWorker 无法形成可恢复的生产闭环；误用开发配置还可能启用已知 Root 凭据或不实际发送验证码。
建议	按生产任务卡完成内网网络、外部化密钥、持久卷、Nginx/HTTPS、systemd/Compose 生命周期、备份恢复和资源预算。
证据	docker-compose.yml:1-21；docs/ai/tasks/OJ-PRODUCTION-DEPLOY-01.md:57-106

4. 其他重要问题

领域	问题摘要	建议
判题结果	MemoryLimitExceeded 没有生产赋值路径，MemoryUsedKb 未采集；时间包含容器启动开销。	识别 OOM 退出，采集峰值内存，并将程序运行时间与容器启动时间分离。
容器加固	缺少只读根文件系统、cap-drop 和 no-new-privileges；共享工作区在 Linux 为 0777。	收缩容器能力、文件权限和挂载范围，并验证 seccomp/AppArmor。
文件上传	图片和 ZIP 主要依赖扩展名及声明 Content-Type；图片没有用户配额和清理策略。	检查文件签名/实际解码，设置配额、保留期和磁盘告警。
文件一致性	Challenge 文件先写磁盘、再写数据库；替换时先删除旧文件，失败可产生孤儿或数据丢失。	采用临时文件 + 原子重命名 + 补偿清理，并避免保存不可迁移的绝对路径。
CSV 导出	CSV 只转义逗号和引号，没有处理以 =、+、-、@ 开头的公式。	对潜在公式单元格添加安全前缀，并增加导出安全测试。
前端身份	JWT 保存在 localStorage；仓库未配置 CSP 和统一安全响应头。	评估 HttpOnly Cookie 或更短 Token 生命周期，并配置 CSP、nosniff 等响应头。

5. 工程质量与测试覆盖

现有优势

- Domain、Application、Infrastructure、API 与 JudgeWorker 的项目边界基本清晰，API 没有直接执行用户代码。
- Root/ProblemSetter 权限策略会重新读取数据库角色，并过滤已删除或拉黑用户。
- 密码采用带随机盐的 PBKDF2；JWT 验证 Issuer、Audience、签名与生命周期。
- Hidden 判题结果在 DTO 层进行了实际输出、期望输出和错误详情脱敏。
- Markdown 使用 rehype-sanitize；前端启用了 TypeScript strict。
- 发布脚本检查干净工作树、删除开发配置、生成迁移包和 SHA256。

测试缺口

- 122 个测试声明主要集中于账号、Function Builder、Parser、排行榜和业务服务。
- 持久化测试主要使用 EF InMemory，无法覆盖 PostgreSQL 约束、事务与 Redis 协调问题。
- 没有 Worker、Redis ACK/恢复、真实 Docker 沙箱、输出洪泛和 Hidden 输入隔离测试。
- 没有空测试点、未发布资源访问、注销 Token、验证码并发测试。
- 前端没有单元测试、组件测试、E2E 框架或 lint 脚本；仓库没有 CI/CD 工作流。

维护性问题

- ChallengeService 约 1700 行，ProblemService 约 840 行，业务规则与 EF 查询高度集中。
- frontend/src/styles.css 约 189 KB，缺少模块化样式边界。
- frontend/src.zip 与 frontend/public.zip 和活动源码重复，存在版本漂移风险。
- README 与 Context Capsule 已出现框架版本、迁移状态、前端地址和工作目录漂移。

6. 技术生命周期

全部项目目标为 .NET 9，但仓库没有 global.json，构建机可能选择不同主版本 SDK。当前 Microsoft 包主要为 9.0.15/9.0.16，而审计日微软列出的最新 .NET 9 补丁为 9.0.19。

微软官方支持策略显示 .NET 9 为 STS，将于 2026-11-10 结束支持。生产上线前应规划迁移到 .NET 10 LTS，并统一 SDK 和包补丁版本。

参考：<https://dotnet.microsoft.com/en-us/platform/support/policy>

7. 建议整改路线

阶段	整改主题	最低验收证据
第一阶段	队列可靠性、Worker 终态、幂等与恢复	并发提交、数据库失败、Worker 崩溃和 Redis 重启场景均可自动恢复。
第二阶段	测试点隔离、输出上限、容器清理与能力收缩	恶意程序无法读取其他测试输入；洪泛输出受限；超时后无残留容器。
第三阶段	发布状态、有效用户、密码、验证码和请求边界	未发布内容不可被非管理者读取或提交；注销/拉黑立即生效；并发验证码测试通过。
第四阶段	生产网络、密钥、持久化、TLS、健康检查和备份	PostgreSQL/Redis/Docker 不公网暴露；重启和回滚后数据完整；恢复演练通过。
第五阶段	PostgreSQL/Redis/Docker 集成测试、CI、.NET 10 和文档同步	后端、前端、迁移和三语言沙箱在 CI/目标主机上形成可重复证据。

上线裁决

当前状态：不建议公网发布。完成至少第一至第四阶段并取得运行级验证证据后，再进行上线评审。

验证边界

本报告是单轮只读静态审计摘要，不等于渗透测试、NuGet/npm 漏洞数据库扫描、真实 PostgreSQL/Redis/Docker 集成测试或生产主机验收。所有运行级结论在执行相应验证前均应视为未验证。